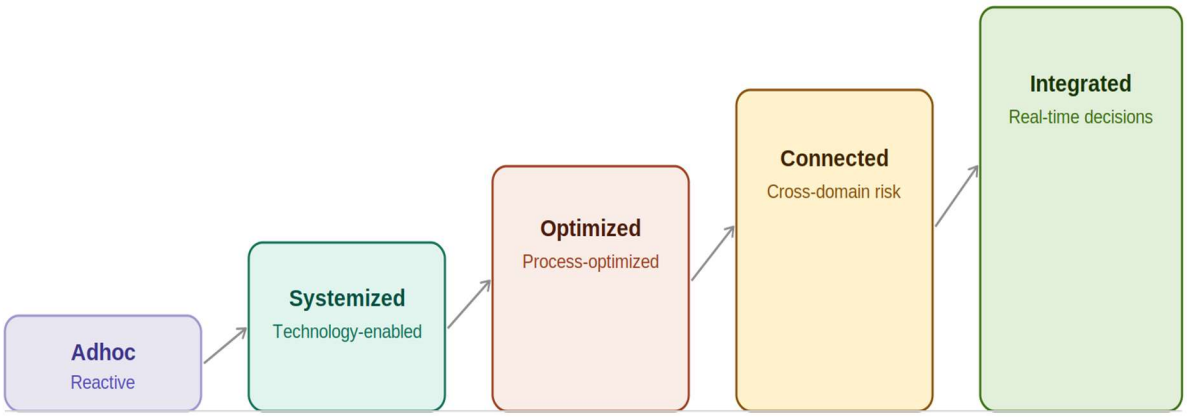
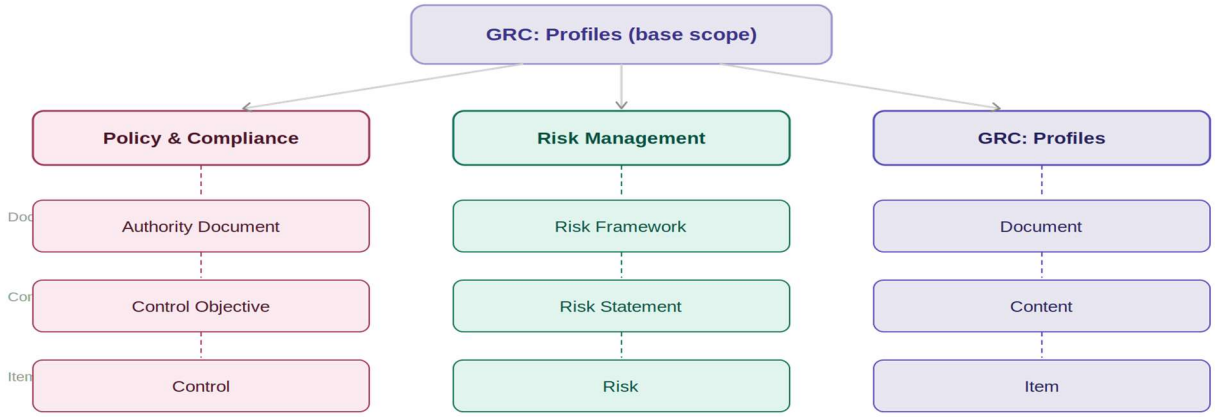
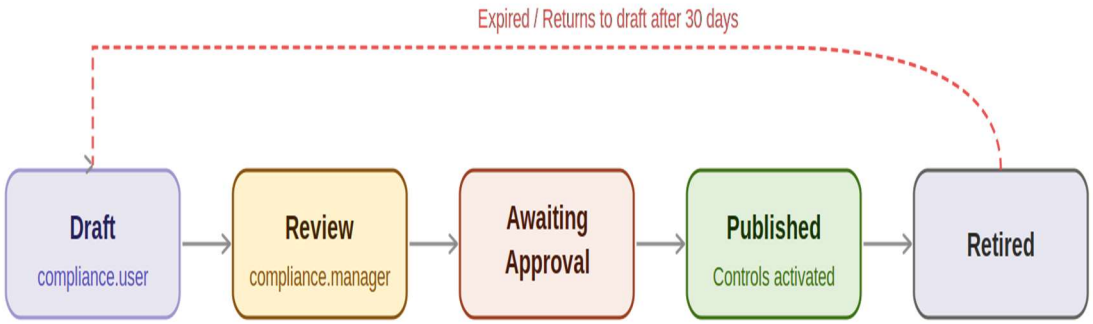
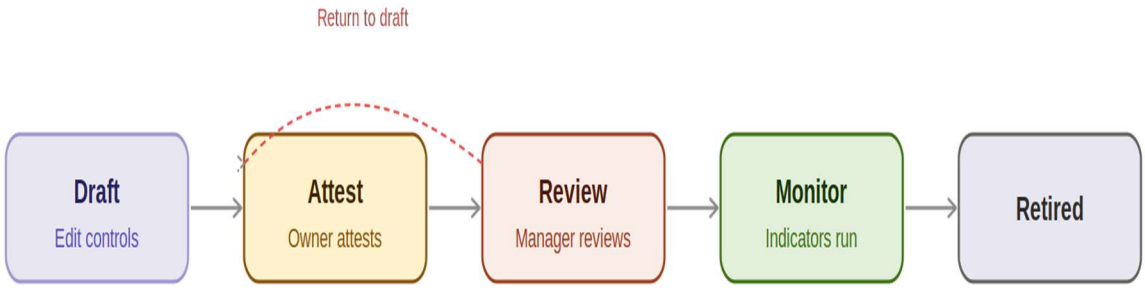
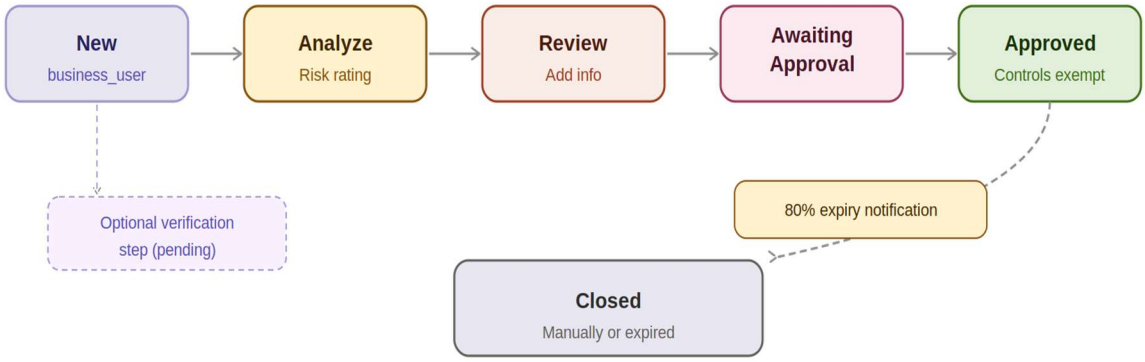
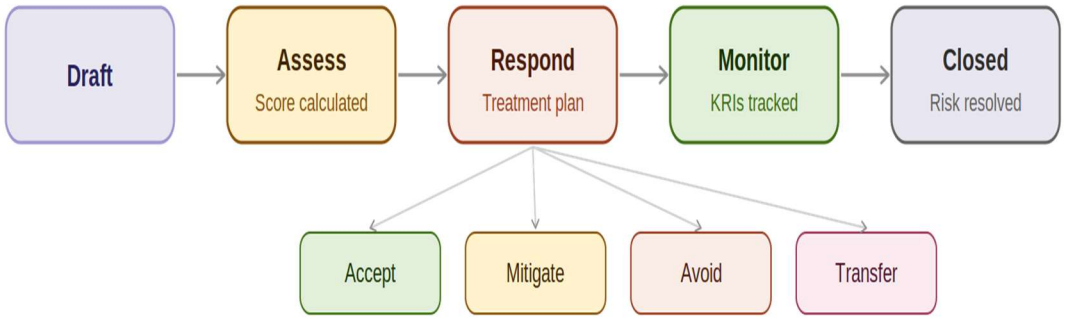

Adhoc
Reactive
Systemized
Technology-enabled
Optimized
Process-optimized
Connected
Cross-domain risk
Integrated
Real-time decisions

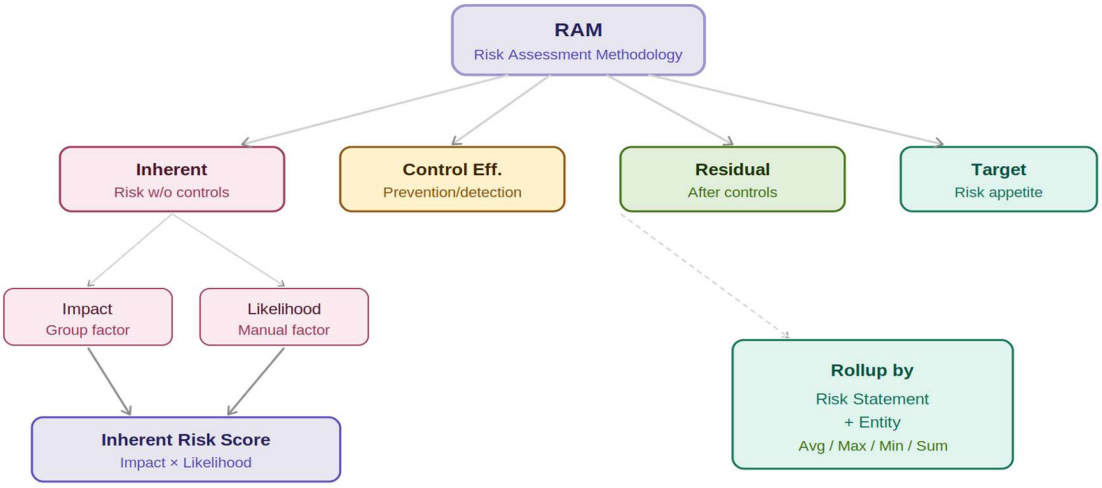

GRC: Profiles (base scope)
Policy & Compliance
Risk Management
GRC: Profiles
Doc
Authority Document
Risk Framework
Document
Cor
Control Objective
Risk Statement
Content
Item
Control
Risk
Item

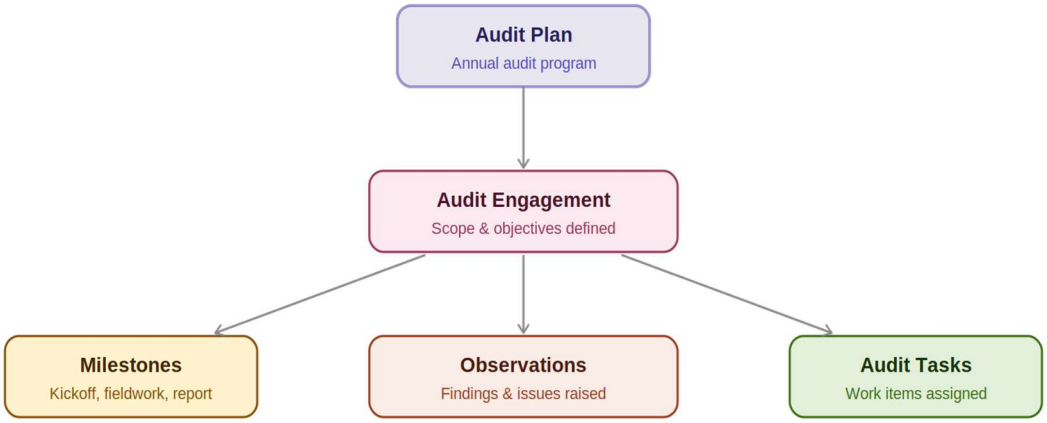

Expired / Returns to draft after 30 days
Draft
compliance.user
Review
compliance.manager
Awaiting Approval
Published
Controls activated
Retired

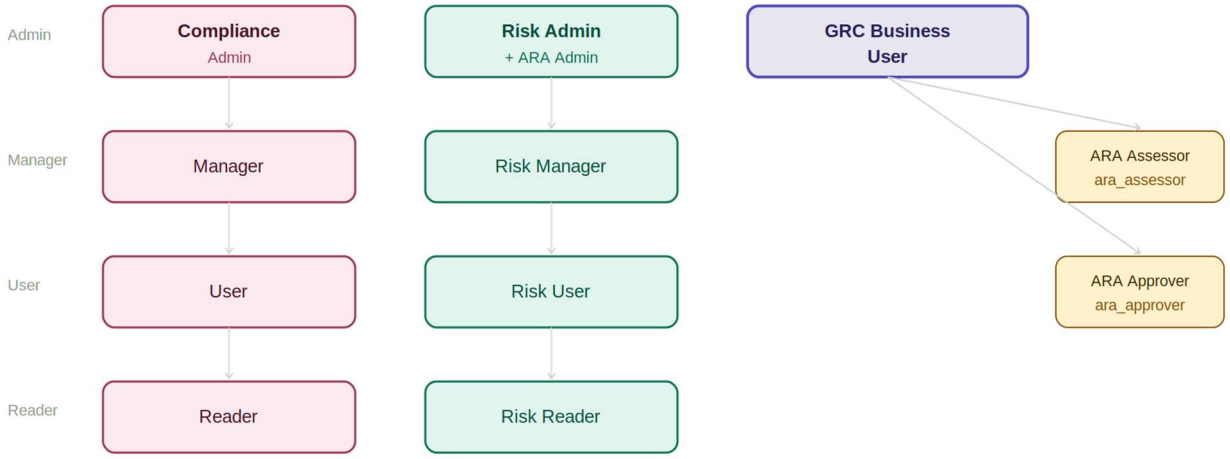

Return to draft
Draft
Edit controls
Attest
Owner attests
Review
Manager reviews
Monitor
Indicators run
Retired

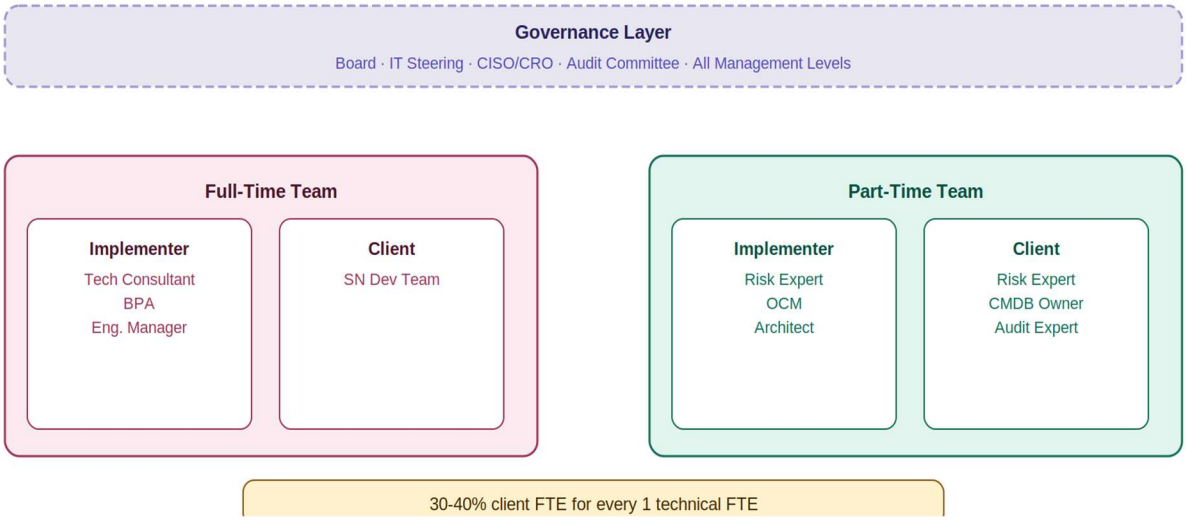

New
business_user
Analyze
Risk rating
Review
Add info
Awaiting Approval
Approved
Controls exempt
Optional verification step (pending)
80% expiry notification
Closed
Manually or expired

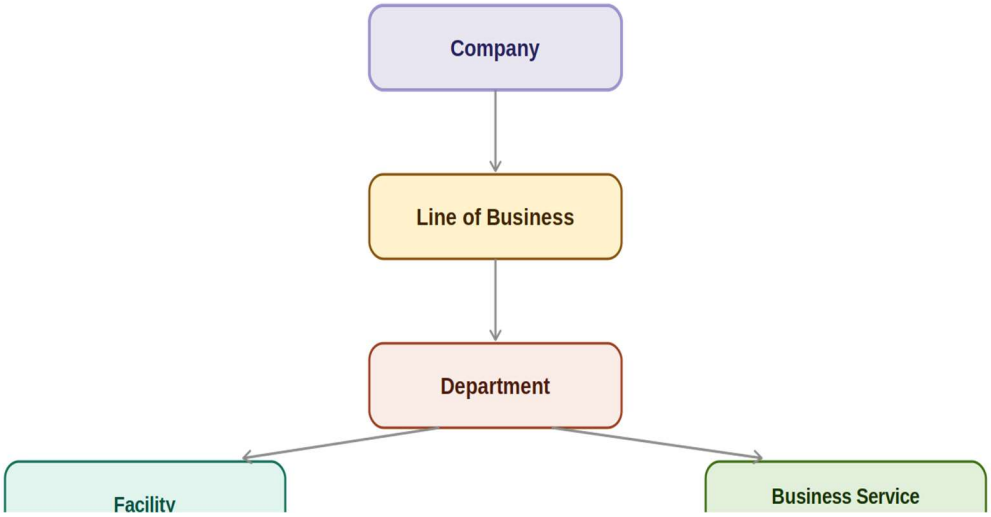

Draft
Assess
Score calculated
Respond
Treatment plan
Monitor
KRIs tracked
Closed
Risk resolved
Accept
Mitigate
Avoid
Transfer

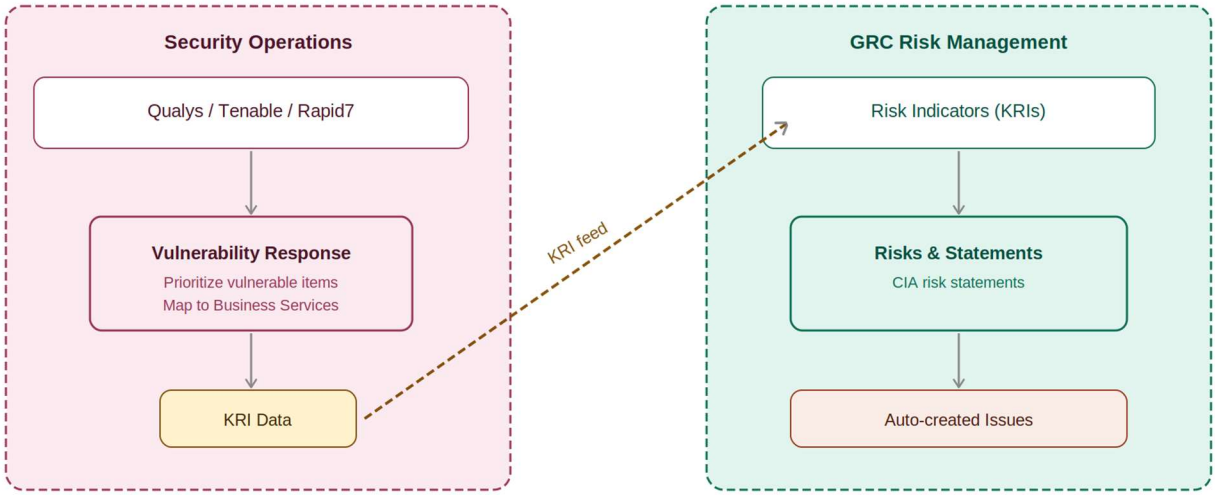

RAM
Risk Assessment Methodology
Inherent
Risk w/o controls
Control Eff.
Prevention/detection
Residual
After controls
Target
Risk appetite
Impact
Group factor
Likelihood
Manual factor
Inherent Risk Score
Impact × Likelihood
Rollup by
Risk Statement
+ Entity
Avg / Max / Min / Sum


Audit Plan
Annual audit program
Audit Engagement
Scope & objectives defined
Milestones
Kickoff, fieldwork, report
Observations
Findings & issues raised
Audit Tasks
Work items assigned


Admin
Manager
User
Reader
Compliance
Admin
Manager
User
Reader
Risk Admin
+ ARA Admin
Risk Manager
Risk User
Risk Reader
GRC Business User
ARA Assessor
ara_assessor
ARA Approver
ara_approver


Governance Layer
Board · IT Steering · CISO/CRO · Audit Committee · All Management Levels
Full-Time Team
Implementer
Tech Consultant
BPA
Eng. Manager
Client
SN Dev Team
Part-Time Team
Implementer
Risk Expert
OCM
Architect
Client
Risk Expert
CMDB Owner
Audit Expert
30-40% client FTE for every 1 technical FTE


Company
Line of Business
Department
Facility
Business Service

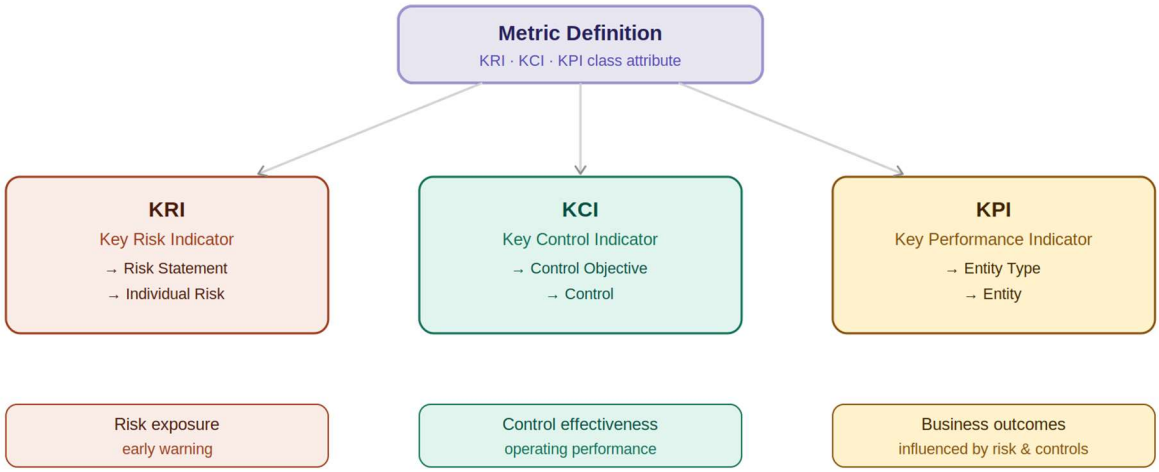

Security Operations
Qualys / Tenable / Rapid7
Vulnerability Response
Prioritize vulnerable items
Map to Business Services
KRI Data
KRI feed
GRC Risk Management
Risk Indicators (KRIs)
Risks & Statements
CIA risk statements
Auto-created Issues

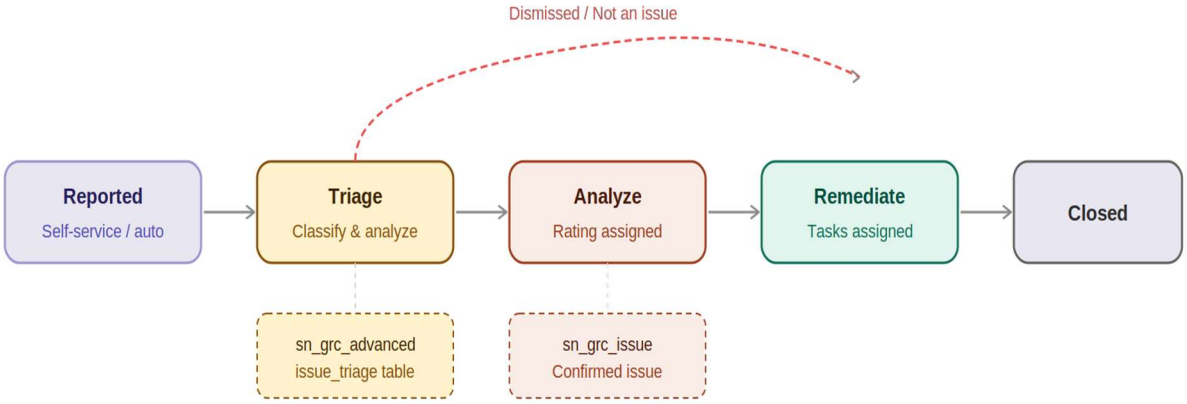
Indicators

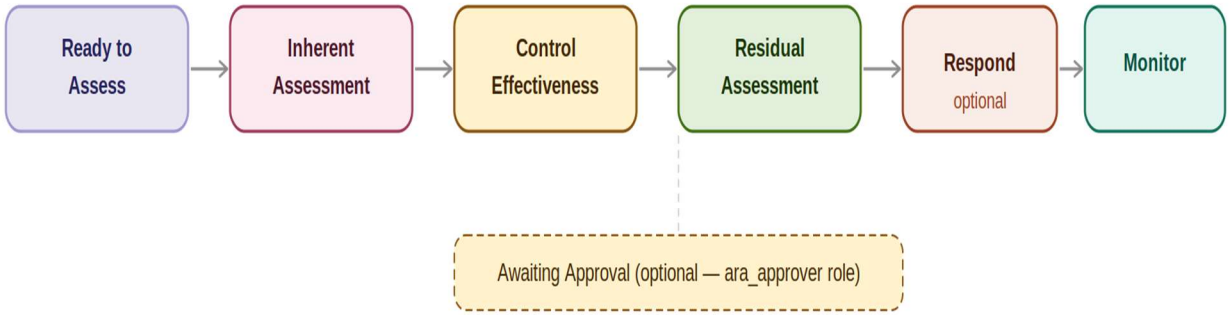
- Monitor risk or control
- Binary result: Pass / Fail
- Supports sample size
- Not replaced by metrics

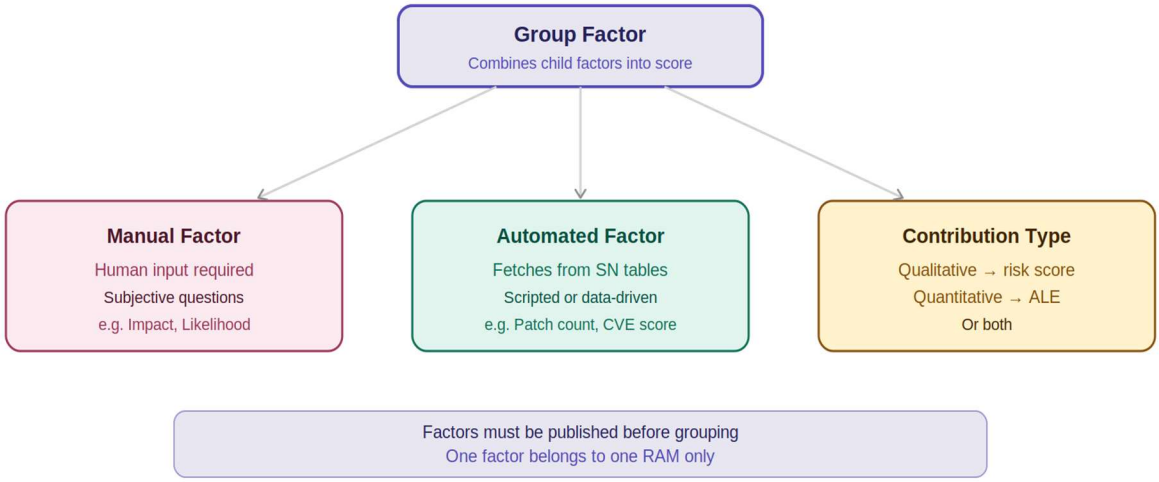
Metrics

- Measure any GRC object
- Variable results: number, %, amount, ratio
- Supports aggregation
- Supports confidentiality

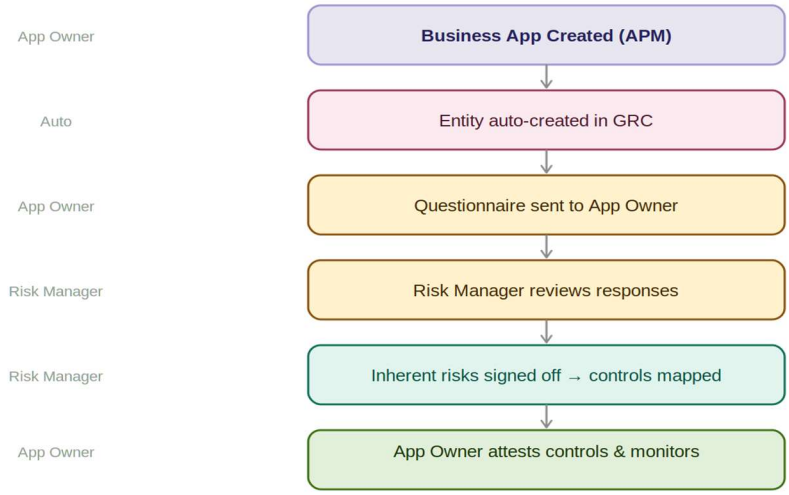

Metric Definition
KRI · KCI · KPI class attribute
KRI
Key Risk Indicator
→ Risk Statement
→ Individual Risk
KCI
Key Control Indicator
→ Control Objective
→ Control
KPI
Key Performance Indicator
→ Entity Type
→ Entity
Risk exposure
early warning
Control effectiveness
operating performance
Business outcomes
influenced by risk & controls

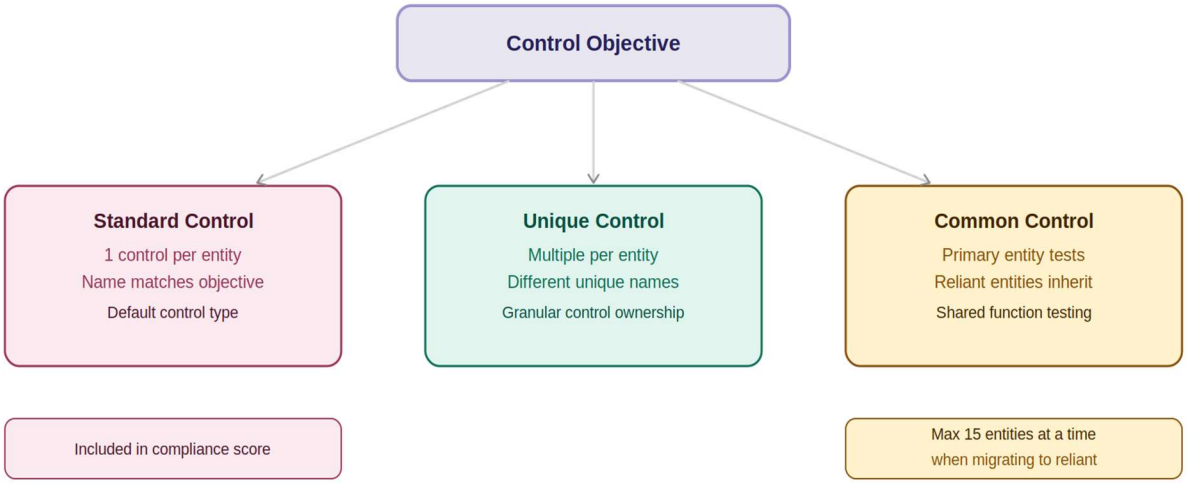

Dismissed / Not an issue
Reported
Self-service / auto
Triage
Classify & analyze
Analyze
Rating assigned
Remediate
Tasks assigned
Closed
sn_grc_advanced
issue_triage table
sn_grc_issue
Confirmed issue

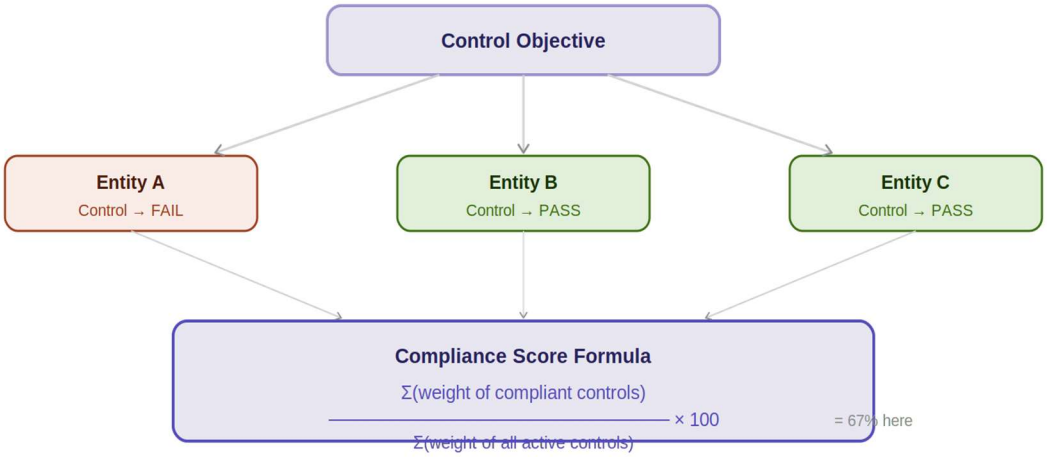

Ready to Assess
Inherent Assessment
Control Effectiveness
Residual Assessment
Respond
optional
Monitor
Awaiting Approval (optional — ara_approver role)

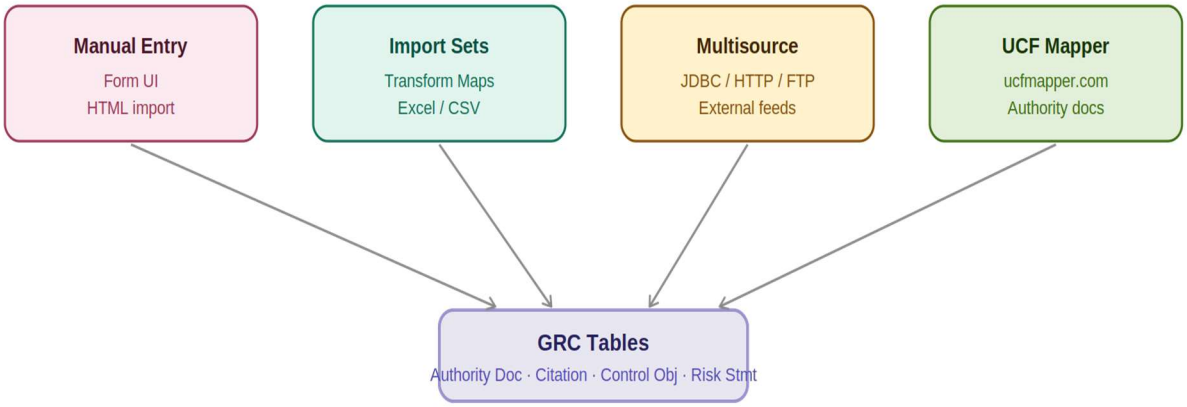


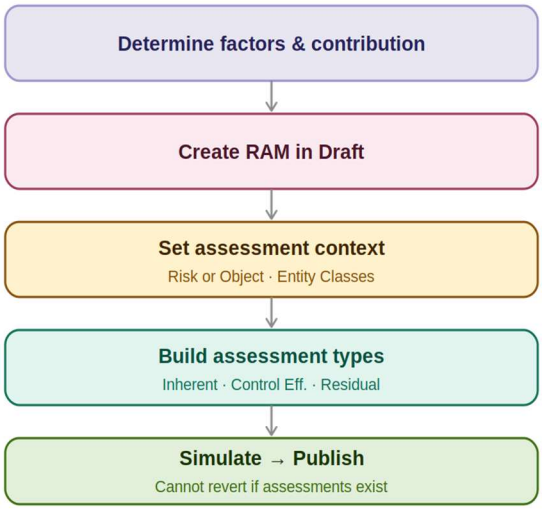
Factors must be published before grouping
One factor belongs to one RAM only

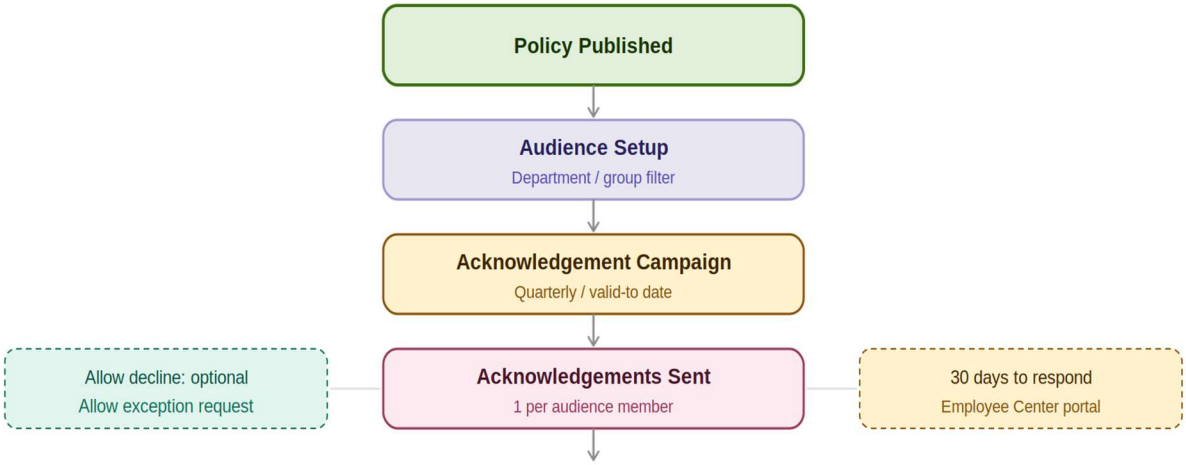

App Owner
Business App Created (APM)
Auto
Entity auto-created in GRC
App Owner
Questionnaire sent to App Owner
Risk Manager
Risk Manager reviews responses
Risk Manager
Inherent risks signed off → controls mapped
App Owner
App Owner attests controls & monitors

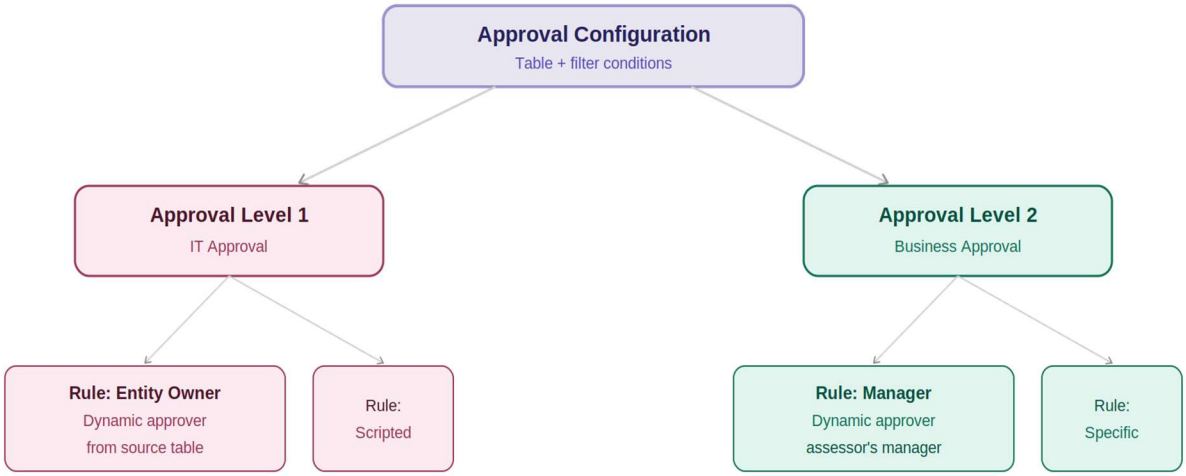

Control Objective
Standard Control
1 control per entity
Name matches objective
Default control type
Unique Control
Multiple per entity
Different unique names
Granular control ownership
Common Control
Primary entity tests
Reliant entities inherit
Shared function testing
Included in compliance score
Max 15 entities at a time
when migrating to reliant


Control Objective
Entity A
Control → FAIL
Entity B
Control → PASS
Entity C
Control → PASS
Compliance Score Formula
Σ(weight of compliant controls)
Σ(weight of all active controls)
× 100
= 67% here


Manual Entry
Form UI
HTML import
Import Sets
Transform Maps
Excel / CSV
Multisource
JDBC / HTTP / FTP
External feeds
UCF Mapper
ucfmapper.com
Authority docs
GRC Tables
Authority Doc · Citation · Control Obj · Risk Stmt


Determine factors & contribution
Create RAM in Draft
Set assessment context
Risk or Object · Entity Classes
Build assessment types
Inherent · Control Eff. · Residual
Simulate → Publish
Cannot revert if assessments exist


Policy Published
Audience Setup
Department / group filter
Acknowledgement Campaign
Quarterly / valid-to date
Acknowledgements Sent
1 per audience member
Allow decline: optional
Allow exception request
30 days to respond
Employee Center portal


Approval Configuration
Table + filter conditions
Approval Level 1
IT Approval
Approval Level 2
Business Approval
Rule: Entity Owner
Dynamic approver
from source table
Rule:
Scripted
Rule: Manager
Dynamic approver
assessor's manager
Rule:
Specific